

Cybersecurity Risk & Governance Assessment

Northstar Financial Group (NFG)

PRELIMINARY ASSESSMENT REPORT

Prepared By	Ryan Bryant
Role	Cybersecurity Analyst (Portfolio Exercise)
Assessment Date	September 2, 2026
Framework Basis	NIST Cybersecurity Framework (CSF) 2.0

Scope Note

This report documents a fictional cybersecurity assessment created as a professional portfolio exercise. Findings are based on simulated stakeholder interviews, asset information, and analyst evaluation developed during the exercise.

1. Executive Summary

Northstar Financial Group (NFG) is a fictional 75-employee financial-services organization operating a hybrid workforce with Microsoft 365, Windows endpoints, Active Directory, cloud services, remote access, and a third-party IT provider. The purpose of this preliminary assessment is to identify material cybersecurity risks, translate those risks into business impact, and establish a prioritized foundation for remediation and future governance work.

The discovery phase identified eleven preliminary risk findings. Three are currently assessed as Critical and eight as High. The most significant themes are backup resilience, identity and access management, data governance, third-party oversight, incident preparedness, software and endpoint governance, patching, asset lifecycle management, and security logging.

Executive Risk Statement

Northstar has several useful security controls in place, but many controls rely on informal practice rather than documented governance, validated procedures, or consistent oversight. This creates a material risk that a preventable incident could become more disruptive because access, recovery, response, evidence, and accountability are not yet managed as a coordinated security program.

Preliminary Risk Distribution

Critical	High	Moderate	Low
3	8	0	0

Immediate Priorities

- Strengthen backup resilience by separating backup administration, validating restoration, and adding offline or immutable recovery capability.
- Remove inappropriate MFA exceptions, formalize account offboarding, and review service-account authentication and privilege.
- Create a formal data-classification and handling standard for sensitive customer, employee, financial, and executive information.
- Establish documented governance for incident response, third-party access, patching, software approval, logging, and asset lifecycle management.

2. Assessment Approach

This preliminary assessment uses an evidence-driven, qualitative risk methodology. Information was gathered from simulated stakeholder interviews and an initial asset inventory. Each finding separates stakeholder evidence from analyst interpretation so that the resulting risk statement is traceable to observed conditions rather than unsupported assumptions.

Risk Register Fields

Field	Purpose
Asset / Process	The system, data set, business function, or control area affected.
Threat	The event or actor capable of causing harm.
Vulnerability	The weakness or control gap that may be exploited or may worsen an incident.
Likelihood	Qualitative estimate of how reasonably the risk could occur under current conditions.
Impact	Potential operational, financial, legal, customer, workforce, or reputational consequence.
Risk Level	Overall preliminary risk rating based on likelihood and impact.
Recommended Control	The principal action or control needed to reduce the risk.
Owner	Proposed business or technical function accountable for coordinating remediation.
Priority	Suggested remediation priority relative to the other findings.

NIST CSF 2.0 Alignment

The assessment is organized with the NIST Cybersecurity Framework (CSF) 2.0 in mind. CSF 2.0 provides six concurrent Functions—Govern, Identify, Protect, Detect, Respond, and Recover—and is designed to help organizations understand, assess, prioritize, and communicate cybersecurity risk. This report uses Function-level alignment as a preliminary portfolio mapping rather than a formal conformance determination.

3. Organizational Context

Company Profile

Organization	Northstar Financial Group (NFG)
Industry	Financial services
Employees	75

Work Model	Headquarters plus remote employees
IT Staff	4
Dedicated Security Staff	Cybersecurity Analyst role introduced for this exercise

Technology Environment

- Microsoft 365 for email and collaboration
- Windows 11 employee workstations
- Windows Server Active Directory and Microsoft Entra ID
- Internal file server
- Cloud-based customer relationship management (CRM) platform
- Cloud-based payroll system
- VPN for remote access
- Company-issued laptops for remote employees
- Managed corporate Wi-Fi
- Third-party IT support provider
- Nightly backups
- Endpoint antivirus and a basic perimeter firewall

Sensitive Information

- Customer personally identifiable information (PII), including names, addresses, phone numbers, email addresses, and Social Security numbers.
- Customer financial information, including account information, investment documents, and financial-planning records.
- Employee information, including payroll, tax documents, and personnel records.

4. Asset Inventory and Criticality

Asset ID	Asset	Purpose	Owner	Criticality
NFG-001	Active Directory	Authentication and identity	IT	Critical
NFG-002	Microsoft 365	Email and collaboration	IT	High
NFG-003	Customer CRM	Customer and account management	Sales	Critical
NFG-004	File Server	Internal documents	IT	Not yet rated

Asset ID	Asset	Purpose	Owner	Criticality
NFG-005	Payroll SaaS	Employee payroll	HR	Critical
NFG-006	Employee Laptops	Daily employee operations	IT	Not yet rated
NFG-007	VPN	Remote access	IT	Not yet rated
NFG-008	Backup System	Data recovery	IT	High*
NFG-009	Corporate Wi-Fi	Network connectivity	IT	Not yet rated
NFG-010	Financial Records	Customer financial data	Finance	Not yet rated

* Backup System was rated High during the initial asset exercise, with the analyst noting that it should be elevated to Critical if it is Northstar's only viable recovery mechanism. Remaining assets have not yet received formal criticality ratings.

Criticality Rationale for Assessed Assets

NFG-001 — Active Directory | Critical

Loss of Active Directory could prevent employees from authenticating to organizational systems and accessing critical resources, creating widespread operational disruption and significant productivity loss.

NFG-002 — Microsoft 365 | High

An interruption would significantly hinder communication and collaboration across departments. Some business operations could continue, but workflow coordination, communication, and operational efficiency would be materially reduced.

NFG-003 — Customer CRM | Critical

An interruption could severely affect customer service and account management. Extended downtime could lead to lost revenue, delayed services, poor customer experience, and reputational damage.

NFG-005 — Payroll SaaS | Critical

A prolonged interruption could prevent employees from being paid accurately or on time, potentially reducing morale and trust while creating financial, legal, and workforce consequences.

NFG-008 — Backup System | High, potentially Critical

The backup system is essential for restoring operations after ransomware, hardware failure, or disaster. Its criticality depends on whether alternate recovery capability exists and on the organization's defined recovery objectives.

5. Preliminary Risk Register

The following register consolidates the discovery findings into a portfolio-ready risk-management format. Ratings are preliminary and should be validated through technical evidence, contractual review, policy review, and management risk-tolerance discussions before being treated as final.

ID	Asset / Process	Threat	Vulnerability	Likelihood	Impact	Risk Level	Recommended Control	Owner	Priority
R-01	Backup / Recovery	Ransomware, disaster, credential compromise	Always-on NAS; shared AD admin credentials; no offline/immutable copy; no full restore test	High	Critical	Critical	Separate backup credentials; add isolated/immutable copy; conduct restore tests; define recovery procedures	IT	1
R-02	Identity & Offboarding	Phishing, credential theft, unauthorized former-user access	MFA exceptions for executives/managers; unmanaged service-account exceptions; manual deprovisioning delays	High	Critical	Critical	Enforce MFA for human accounts; review service identities; formalize same-time access revocation and session termination	IT + HR	1
R-03	Third-Party IT Services	Vendor compromise, supply-chain intrusion	No formal vendor security review; unclear breach-notification terms; privileged vendor access lacks demonstrated oversight	Moderate	Critical	High	Perform vendor security review; document access; strengthen authentication; define contractual security and incident obligations	Executive + IT + Legal	2
R-04	Finance Access Control	Account compromise, insider misuse	Broad Finance-folder access; stale permissions; privilege creep after role changes	High	High	High	Implement role-based access; separate sensitive data; quarterly access reviews; immediate mover reviews	Finance + IT	2
R-05	Endpoint Software & Media	Malicious/vulnerable software, unauthorized remote access, data	Uncontrolled software/extensions; no approved list; personal USB use	High	High	High	Create approved-software process; restrict installs; inventory applications;	IT + Operations	2

ID	Asset / Process	Threat	Vulnerability	Likelihood	Impact	Risk Level	Recommended Control	Owner	Priority
		loss					prohibit personal USB; issue encrypted managed media by exception		
R-06	Incident Response	Ransomware, breach, destructive malware	No written IR plan; unclear roles; no exercise; uncertain insurance/notification procedures	Moderate	Critical	High	Create formal IR plan; define roles and escalation; preserve evidence; coordinate legal/vendor/insurance; conduct tabletop exercises	Security + IT + Executive	2
R-07	Awareness & Account Compromise	Phishing, credential theft, session hijack	One-time training; no simulations; prior phished account handled mainly by password reset	High	High	High	Recurring awareness training; phishing exercises; documented account-compromise investigation, session revocation, MFA review, and validation	HR + IT/Security	2
R-08	Data Governance	Accidental disclosure, insider misuse, unauthorized sharing	No formal classification or handling rules for sensitive digital and physical information	High	Critical	Critical	Create classification tiers and handling rules for access, storage, transmission, printing, retention, encryption, and disposal	Security + Data Owners	1
R-09	Patch Management	Exploitation of known vulnerabilities	No centralized patch tracking; no remediation timelines; postponed updates; limited validation	High	High	High	Centralize patch reporting; define severity-based SLAs; test exceptions; verify deployment and configuration compliance	IT	2
R-10	Asset Lifecycle	Loss, theft, unauthorized reuse, residual data exposure	Incomplete inventory; returned devices may sit in storage; no formal wipe/reimage/storage	Moderate	High	High	Maintain authoritative asset inventory; formalize return, evidence/data	IT + HR	2

ID	Asset / Process	Threat	Vulnerability	Likelihood	Impact	Risk Level	Recommended Control	Owner	Priority
			ge process				preservation, wiping, reimaging, storage, reassignment, and disposal		
R-11	Logging & Retention	Undetected or poorly investigated malicious activity	No centralized logging; undefined retention; reliance on third party for some logs	Moderate	High	High	Define logging standard; centralize critical logs; establish retention and access controls; verify third-party log availability and ownership	IT + Security	2

6. Detailed Findings and Interview Evidence

Each finding below preserves the evidence from the simulated stakeholder interview while presenting the analyst’s response in refined professional language suitable for a portfolio deliverable. The evidence statements are intentionally separated from recommendations so that the reader can see how the conclusion was reached.

R-01 | Inadequate Backup Resilience and Recovery Validation

Risk Level	Evidence Source	Proposed Owner	NIST CSF
Critical	IT Manager	IT	Recover, Protect, Govern

Interview Evidence

Northstar performs nightly file-server backups to a network-attached storage (NAS) device at headquarters. The NAS remains connected to the production network, uses the same Active Directory credentials used by IT personnel, has no offline or immutable copy, and has never undergone a full restoration test.

Stakeholder Question / Concern

“Why should we be concerned if the backup jobs are completing successfully?”

Professional Analyst Assessment

The primary concern is that Northstar’s recovery capability may fail during the same event that disrupts production. A continuously reachable NAS could be affected by ransomware or credential compromise, and shared administrative credentials increase the chance that one stolen identity could expose both production and backup resources. A successful backup job also does not prove that the organization can restore systems. Northstar should validate recovery through scheduled restoration testing and documented recovery procedures.

Potential Business Impact

A ransomware attack, infrastructure failure, natural disaster, or administrative-account compromise could leave production data and backups simultaneously inaccessible, corrupted, or encrypted. This could cause prolonged business interruption and data loss.

Recommended Controls

- Use dedicated backup-management credentials that are separate from normal IT administrator accounts.
- Introduce an offline, immutable, or otherwise isolated backup copy.
- Conduct scheduled full or representative restoration testing and document results.
- Document recovery roles and base backup schedules on approved RPO/RTO targets.

R-02 | MFA Exceptions and Inconsistent Account Deprovisioning

Risk Level	Evidence Source	Proposed Owner	NIST CSF
Critical	HR Manager	IT + HR	Protect, Govern

Interview Evidence

Approximately eight Microsoft 365 accounts do not require MFA, including executive, department-manager, and older service accounts. HR requests account disablement by email when employees leave, but access removal can occasionally take several days.

Stakeholder Question / Concern

“Is this really a serious problem if most employees already use MFA?”

Professional Analyst Assessment

MFA exceptions are especially concerning for executive and management accounts because those identities may have access to sensitive information and can also be abused for high-impact social engineering. Service accounts require separate analysis because interactive MFA may not be appropriate, but they should not be exempted without compensating authentication, credential-management, and least-privilege controls. Employee access should be revoked at the effective time of separation, including active sessions and remote access; accounts do not necessarily need to be immediately deleted if retention or legal requirements apply.

Potential Business Impact

A compromised privileged or high-value account could expose sensitive customer or company information, enable fraudulent business communications, or provide persistent access. Delayed offboarding can also leave former employees with continued access.

Recommended Controls

- Require MFA for all eligible human accounts, with particularly strong controls for executives and administrators.
- Inventory and review service accounts individually; remove unnecessary accounts and apply appropriate workload/service identity controls.
- Create a formal joiner/mover/leaver process with immediate access suspension at the effective time of separation.
- Revoke active sessions, VPN access, tokens, and other authentication mechanisms during offboarding.
- Periodically review privileged and exception accounts.

R-03 | Inadequate Third-Party Security Oversight

Risk Level	Evidence Source	Proposed Owner	NIST CSF
High	CEO	Executive + IT + Legal	Govern

Interview Evidence

Northstar’s third-party IT provider has administrative access to some servers and manages the firewall and VPN. The provider has been trusted for approximately six years, but Northstar has not conducted a formal cybersecurity review and management is unsure whether the contract establishes specific incident-notification requirements.

Stakeholder Question / Concern

“They have worked with us for six years without a problem. Why should we investigate a company we already trust?”

Professional Analyst Assessment

A long working relationship is useful operational evidence, but trust should be supported by defined security requirements and periodic assurance. Because the provider has privileged access to critical infrastructure, a compromise of the vendor could directly affect Northstar. Outsourcing IT operations does not transfer Northstar’s responsibility for business risk, customer data, or incident response. The objective is not to distrust the vendor; it is to ensure that privileged access and contractual obligations are governed proportionately to their importance.

Potential Business Impact

A third-party compromise could provide attackers with a trusted path into Northstar’s systems. Delayed vendor notification could prevent timely containment, evidence preservation, customer protection, and fulfillment of legal, contractual, or insurance obligations.

Recommended Controls

- Conduct an annual vendor security review and document evidence of relevant controls.
- Maintain an inventory of vendor accounts, systems, and privileges.
- Require individual, strongly authenticated administrative access and periodically review it.
- Establish immediate third-party access revocation procedures.
- Review contracts for breach notification, incident cooperation, data handling, access termination, and security responsibilities.

R-04 | Excessive Access and Privilege Creep

Risk Level	Evidence Source	Proposed Owner	NIST CSF
High	Finance Director	Finance + IT	Protect, Govern

Interview Evidence

All Finance employees can access a shared folder containing payroll reports, customer financial records, banking information, tax documents, and executive financial reports. Old permissions may not always be removed when employees change departments, allowing access to accumulate over time.

Stakeholder Question / Concern

“If everyone in Finance works for the company, why does it matter if they can all see the same files?”

Professional Analyst Assessment

The issue is not simply that Finance uses a shared folder; it is that the folder contains multiple categories of sensitive information that may not be necessary for every role. Access should be aligned to current job responsibilities and removed when those responsibilities change. Otherwise, a compromised ordinary user account may inherit years of unnecessary permissions without the attacker needing to perform additional privilege escalation.

Potential Business Impact

A compromised or misused account could expose payroll, banking, customer, tax, or executive information beyond the legitimate business need of the user.

Recommended Controls

- Implement role-based access control (RBAC) for Finance data.
- Separate sensitive data into access groups based on business need.
- Perform quarterly formal access reviews.
- Require immediate access review whenever an employee changes roles or departments.
- Remove obsolete and individually assigned permissions where group-based access is more appropriate.

R-05 | Uncontrolled Software and Removable Media

Risk Level	Evidence Source	Proposed Owner	NIST CSF
High	Operations Manager	IT + Operations	Protect, Identify

Interview Evidence

Employees can install some applications themselves. Northstar has no formal approved-software list, employees use browser extensions and free utilities from the internet, and some staff use personal USB drives to move documents between systems.

Stakeholder Question / Concern

“If antivirus is installed, is that enough to protect the laptops?”

Professional Analyst Assessment

Antivirus is only one layer of endpoint protection. Uncontrolled software, browser extensions, remote-access utilities, and removable media can introduce vulnerable or malicious code, inconsistent configurations, licensing problems, or unauthorized data movement. Northstar should own the software-approval policy rather than relying on a third-party contract to define acceptable applications. Standardization reduces the attack surface and makes patching, monitoring, and support more reliable.

Potential Business Impact

Unapproved software could introduce exploitable vulnerabilities or unauthorized remote access. Personal removable media could introduce malware or enable accidental or intentional data loss.

Recommended Controls

- Create and maintain an approved-software policy and inventory.
- Restrict local installation privileges where practical and require IT review for new applications.
- Remove unnecessary remote-access tools and unsupported utilities.
- Prohibit personally owned USB storage on company systems.
- When removable media is required, issue inventoried, company-owned encrypted devices with documented user, department, business purpose, and centralized recovery information.
- Scan approved removable media and securely wipe devices before reassignment.

R-06 | Lack of Formal Incident-Response Planning

Risk Level	Evidence Source	Proposed Owner	NIST CSF
High	IT Manager	Security + IT + Executive	Respond, Recover, Govern

Interview Evidence

Northstar has no written cybersecurity incident-response plan, has never run an incident-response exercise, and has unclear responsibilities for customer notification, legal coordination, cyber-insurance requirements, and executive decision-making during a serious incident.

Stakeholder Question / Concern

“Do we really need a formal incident-response plan if there are only 75 employees?”

Professional Analyst Assessment

The help desk is an important reporting and support function, but it does not replace a documented response process. During a serious incident, Northstar may need to coordinate IT, executive leadership, legal counsel, the third-party provider, cyber insurance, communications personnel, and customers at the same time. Roles, escalation paths, evidence-preservation procedures, and decision authority should be established before an incident occurs. Employees need role-appropriate training rather than every employee memorizing the full technical plan.

Potential Business Impact

Unclear responsibilities could delay containment and recovery, cause loss of forensic evidence, prolong service disruption, produce inconsistent communications, or allow malicious activity to persist after systems are restored.

Recommended Controls

- Develop a formal incident-response plan with roles, escalation paths, communication responsibilities, evidence handling, and recovery procedures.
- Define coordination requirements for the third-party IT provider, legal counsel, cyber insurer, and executives.
- Train employees on role-specific incident responsibilities and reporting procedures.
- Conduct periodic tabletop exercises and document lessons learned.
- Require post-incident validation to confirm persistence, compromised credentials, and secondary malicious activity have been addressed.

R-07 | Inadequate Security Awareness and Credential-Compromise Response

Risk Level	Evidence Source	Proposed Owner	NIST CSF
High	HR Manager	HR + IT/Security	Protect, Respond

Interview Evidence

Employees receive cybersecurity training only during onboarding. Northstar has not conducted phishing simulations. A user previously entered Microsoft 365 credentials into a fake login page; IT changed the password and no broader investigation was described.

Stakeholder Question / Concern

“Why should employees keep taking security training, and was changing the phished password enough?”

Professional Analyst Assessment

Onboarding training is a useful foundation, but threats, attack techniques, and employee habits change over time. Recurring, targeted awareness activities help employees practice recognizing realistic attacks. A known credential-phishing event should also be treated as a potentially compromised account, not merely a password-reset event. The response should investigate sign-in and audit activity, revoke active sessions, verify MFA methods and account changes, and determine whether unauthorized access occurred.

Potential Business Impact

Employees may become less effective at identifying phishing and social-engineering techniques. Incomplete response to stolen credentials could allow unauthorized access to persist after a password change.

Recommended Controls

- Implement recurring security-awareness education and periodic phishing simulations.
- Provide targeted retraining based on observed risk and exercise outcomes.
- Create a simple, documented process for reporting suspicious messages.
- Develop an account-compromise playbook that includes investigation, password reset, session/token revocation, MFA review, account-change review, and validation.

R-08 | Lack of Formal Data Classification and Handling Standards

Risk Level	Evidence Source	Proposed Owner	NIST CSF
Critical	Finance Director	Security + Data Owners	Govern, Identify, Protect

Interview Evidence

Northstar has no formal data-classification scheme. Sensitive files may be labeled “Confidential” informally, employees email financial spreadsheets internally, documents are sometimes sent to outside advisers, and there are no formal rules for email, cloud storage, printing, removable media, retention, or physical-document handling.

Stakeholder Question / Concern

“Everyone knows Social Security numbers are sensitive. Why do we need a formal classification policy?”

Professional Analyst Assessment

Knowing that information is sensitive is not the same as having enforceable handling requirements. A classification framework creates consistent rules for who may access data, where it may be stored, whether encryption is required, how it may be transmitted or printed, how long it should be retained, and how it must be destroyed. Classification also supports access control because permissions can be mapped to the sensitivity of the information and the user’s business role. Physical information must be protected as well; building access does not automatically equal authorization to view every document.

Potential Business Impact

Inconsistent handling of customer, employee, financial, and executive information increases the likelihood of accidental disclosure, unauthorized sharing, excessive access, and regulatory or contractual consequences.

Recommended Controls

- Define a practical classification model such as Public, Internal, Confidential, and Restricted.
- Assign handling rules for access, storage, external sharing, email, printing, encryption, retention, and destruction.
- Apply role-based access to Confidential and Restricted information.
- Establish clean-desk and secure-printing expectations for sensitive physical documents.
- Define approved external-sharing methods for accountants, advisers, and other authorized recipients.

R-09 | Inadequate Patch Management

Risk Level	Evidence Source	Proposed Owner	NIST CSF
High	IT Manager	IT	Identify, Protect

Interview Evidence

Windows generally updates automatically, but Northstar has no centralized patch-management platform, no formal remediation timeline, and some systems postpone updates because of specialized financial software. Patch success and post-update configuration compliance are not consistently audited.

Stakeholder Question / Concern

“If Windows installs updates automatically, why do we need a formal patch-management process?”

Professional Analyst Assessment

Automatic updating is useful but does not provide complete governance or assurance. Northstar needs visibility into which devices received updates, whether installations succeeded, whether third-party applications remain vulnerable, and whether compatibility concerns require controlled exceptions. Significant updates may also require verification that security configurations still meet approved baselines. A formal process should make exceptions visible rather than allowing postponement to become indefinite.

Potential Business Impact

Known vulnerabilities could remain exploitable for extended periods, failed patches may go unnoticed, unsupported applications may remain exposed, and inconsistent configurations may weaken endpoint security.

Recommended Controls

- Implement centralized patch tracking and reporting.
- Define severity-based remediation timelines and escalation procedures.
- Test potentially disruptive updates where necessary.
- Document temporary exceptions and required compensating controls.
- Verify installation success and post-update security configuration compliance.
- Include third-party applications and unsupported software in the patch/vulnerability process.

R-10 | Incomplete Asset Lifecycle Management

Risk Level	Evidence Source	Proposed Owner	NIST CSF
High	IT Manager	IT + HR	Identify, Protect

Interview Evidence

Northstar is unsure whether its laptop inventory is fully current. Older laptops may remain in storage after employees leave, and there is no formal process for return, data preservation, wiping, reimaging, storage, reassignment, or disposal.

Stakeholder Question / Concern

“What is the security risk if returned laptops are simply stored until they are needed again?”

Professional Analyst Assessment

Returned devices may still contain local files, cached credentials, browser sessions, VPN configuration, customer information, or other sensitive data. A device that is no longer actively assigned remains a company information asset and must still be tracked and secured. Northstar also cannot reliably verify patching, encryption, or endpoint coverage if it cannot confidently identify every device and lifecycle state.

Potential Business Impact

Unknown, forgotten, lost, stolen, or improperly reused systems could expose company data, retain active access paths, remain unpatched, or be discarded without appropriate sanitization.

Recommended Controls

- Maintain a centralized authoritative asset inventory with unique identifier, assigned user, location, OS version, encryption status, and lifecycle state.
- Integrate HR offboarding with device return and inventory updates.
- Define procedures for data preservation where required, secure wiping, reimaging, reassignment, storage, and disposal.
- Periodically reconcile physical inventory against management records.

R-11 | Insufficient Security Logging and Retention

Risk Level	Evidence Source	Proposed Owner	NIST CSF
High	IT Manager	IT + Security	Detect, Respond, Govern

Interview Evidence

Logs are primarily retained locally or within individual cloud services. Northstar does not centrally collect security logs, has no written retention standard, and may need to request firewall logs from the third-party provider after an incident.

Stakeholder Question / Concern

“We are not a SOC. Why spend money storing logs nobody looks at every day?”

Professional Analyst Assessment

Centralized logging is not only for organizations with a 24/7 SOC. Logs provide evidence of what occurred before, during, and after a security event and can establish which accounts were used, what systems were accessed, and how an incident developed. Historical evidence also supports incident-response improvement and more realistic employee training. Northstar should know what is logged, where records are stored, who controls them, and how long they are retained—especially when a third party controls part of the evidence.

Potential Business Impact

During an incident, Northstar may be unable to reconstruct the attack timeline, identify compromised accounts, determine affected systems or data, or support insurance, legal, contractual, or regulatory investigations.

Recommended Controls

- Define a formal logging standard for required systems, event types, retention, access, and storage.
- Centralize logs from critical sources such as Active Directory, Microsoft 365, VPN, firewall, servers, and high-value applications.
- Protect logs from unauthorized modification and restrict access.
- Verify third-party logging, retention, retrieval time, and ownership requirements.
- Use incident findings to refine response procedures, security controls, and awareness training.

7. Preliminary NIST CSF 2.0 Function Alignment

The table below provides a high-level mapping between Northstar’s preliminary findings and the six CSF 2.0 Functions. This is intended to demonstrate portfolio-level framework alignment and to support the next phase: development of a Current-State Profile, Target-State Profile, and prioritized gap analysis.

CSF Function	Related Findings	Assessment Theme
Govern	R-02, R-03, R-04, R-06, R-08, R-11	Policy, accountability, third-party risk, access governance, data governance, incident authority, and logging requirements.
Identify	R-05, R-08, R-09, R-10	Software inventory, information classification, vulnerability/patch visibility, and authoritative asset inventory.
Protect	R-01, R-02, R-04, R-05, R-07, R-08, R-09, R-10	Authentication, least privilege, endpoint governance, security awareness, data handling, patching, and asset lifecycle controls.
Detect	R-11	Centralized security logging and preservation of evidence needed to identify suspicious or malicious activity.
Respond	R-06, R-07, R-11	Incident-response governance, account-compromise handling, evidence, escalation, and coordinated investigation.
Recover	R-01, R-06	Backup resilience, restoration validation, recovery procedures, and post-incident return to trusted operations.

8. Recommended Next Phase

The discovery phase is complete enough to transition from qualitative identification into formal risk prioritization and governance planning. The next phase should validate evidence, assign accountable owners, define risk acceptance criteria, and convert the preliminary register into a current-state and target-state security roadmap.

- Validate each finding with supporting technical, policy, contractual, or configuration evidence.
- Complete criticality ratings for the remaining assets and identify business dependencies between systems.

- Create a qualitative risk matrix and confirm likelihood/impact definitions with management.
- Develop a NIST CSF 2.0 Current-State Profile and Target-State Profile.
- Build a gap analysis and 90-day remediation roadmap focused first on Critical findings.
- Define measurable remediation milestones, evidence requirements, and reassessment dates.
- Create an executive stakeholder presentation summarizing the highest risks, business consequences, investment priorities, and expected risk reduction.

9. Analyst Reflection / Portfolio Value

This exercise demonstrates cybersecurity analysis beyond penetration testing and security-alert detection. The work translates technical and procedural weaknesses into business risk, distinguishes evidence from assumptions, identifies accountable stakeholders, and recommends proportionate controls. The assessment also demonstrates communication with executives and business leaders, identity and access governance, vendor risk, data governance, recovery planning, endpoint governance, incident response, and risk prioritization.

10. Reference

Pascoe, C., Quinn, S., & Scarfone, K. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.CSWP.29>

Framework note: NIST CSF 2.0 is used as a high-level organizing reference. This fictional assessment does not claim formal certification, audit attestation, or regulatory compliance.